MedBridge Health, Inc.
Password and Authentication Policy

1. Purpose

The purpose of this policy is to establish password and authentication requirements for employees, contractors, and other authorized users who access MedBridge Health's systems and information.

Since MedBridge Health handles sensitive patient information, protecting employee accounts is important for preventing unauthorized access, account compromises, and potential data breaches.

This policy explains the requirements for creating secure passwords, using Multi-Factor Authentication (MFA), protecting login credentials, and managing access to company systems.

It also helps MedBridge Health address security risks related to weak passwords, shared accounts, and unauthorized access to Protected Health Information (PHI).

2. Scope

This policy applies to all MedBridge Health employees, contractors, temporary workers, and authorized third-party personnel who have access to company systems, applications, networks, or sensitive information.

It covers employees working at the San Francisco office and those working remotely. Everyone with access to company resources must follow the password and authentication requirements outlined in this policy.

The policy covers the following:

- **Employee Accounts:** Individual accounts used to access company systems, applications, and devices.
- **Cloud Infrastructure:** Amazon Web Services (AWS), including administrative accounts and systems used to manage patient information.
- **Healthcare Applications:** Electronic Health Records (EHR), patient applications, and clinician portals.

- **Identity and Access Management:** Okta and other systems used to manage employee authentication and Multi-Factor Authentication (MFA).
- **Business Applications:** Google Workspace, GitHub, and other approved services used for company operations.
- **Administrative Accounts:** Accounts with elevated privileges used to manage systems, networks, and security settings.
- **Company Devices:** Employee laptops, workstations, and other authorized devices that require user authentication.
- **Network Equipment:** Firewalls, routers, and other network devices that require administrator credentials.

This policy applies to all company-managed accounts and authentication systems, regardless of whether they are accessed from the office or remotely.

Any exceptions to these requirements must follow the approval process outlined in Section 5 of this policy.

3. Roles and Responsibilities

Everyone who has access to MedBridge Health's systems is responsible for keeping their login credentials secure and following the company's authentication requirements.

Since MedBridge Health does not have a dedicated cybersecurity team, the IT Manager, part-time virtual Chief Information Security Officer (vCISO), and department leaders share responsibility for managing account security and reducing unauthorized access risks.

3.1 Security Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Approves the Password and Authentication Policy and provides oversight of major security risks involving user accounts and authentication.
Chief Technology Officer (CTO)	Oversees authentication security for AWS infrastructure, healthcare applications, and administrative systems.
Virtual Chief Information Security Officer (vCISO)	Maintains the policy, reviews authentication risks, and makes sure password requirements stay aligned with the company's security needs.
IT Manager	Manages employee accounts, password requirements, MFA, account recovery, and authentication-related security issues.

Privacy Officer (COO)	Reviews incidents involving unauthorized access to patient information and helps determine whether HIPAA reporting requirements apply.
HR Manager	Coordinates employee onboarding and offboarding and notifies the IT Manager when user access needs to be created or removed.
Employees and Contractors	Create secure passwords, protect their login credentials, use MFA, and report suspicious account activity.

3.2 Employee and Contractor Responsibilities

Employees and contractors must take reasonable steps to protect their company accounts and prevent unauthorized access.

This includes:

- Creating passwords that meet the company's security requirements.
- Keeping passwords, passphrases, and MFA recovery codes private.
- Using a company-approved password manager to store work-related credentials.
- Never sharing login credentials with coworkers, family members, or unauthorized individuals.
- Reporting suspicious login attempts or possible account compromises to the IT Manager or vCISO immediately.
- Using only their assigned accounts when accessing company systems.

3.3 Management Responsibilities

The IT Manager is responsible for managing workforce authentication settings, reviewing account access, and helping employees resolve account security issues.

The CTO is responsible for making sure technical systems and administrative accounts follow the company's authentication requirements.

The vCISO will work with the IT Manager and department leaders to review authentication risks and recommend improvements when weaknesses are identified.

4. Policy Statements

MedBridge Health requires employees, contractors, and authorized third parties to follow password and authentication requirements when accessing company systems and sensitive information.

These requirements help reduce the risk of account compromise, unauthorized access, and exposure of patient information.

4.1 Password Requirements

1. Workforce passwords must contain at least 16 characters when supported by the authentication system.
2. Employees are encouraged to use long passphrases that are easier to remember but difficult for unauthorized individuals to guess.
3. Password systems must support passwords of at least 64 characters where technically supported.
4. Employees must not use common, easily guessed, or previously compromised passwords.
5. Password creation systems must check new passwords against known compromised-password lists.
6. Employees must not reuse their MedBridge Health passwords for personal accounts or other unrelated services.
7. Passwords must not require specific combinations of uppercase letters, lowercase letters, numbers, and symbols unless a documented technical limitation requires a different approach.

4.2 Password Changes and Account Recovery

1. Employees are not required to change passwords on a fixed schedule, such as every 90 days.
2. Passwords must be changed when there is evidence that an account or password has been compromised.
3. Employees must report suspected password exposure to the IT Manager or vCISO immediately.
4. Password resets must follow an approved process that verifies the identity of the person requesting the reset.
5. Password recovery methods must not rely on security questions based on personal information.
6. Temporary passwords must be randomly generated and replaced after their initial use.

4.3 Multi-Factor Authentication (MFA)

1. MFA must be enabled for all workforce accounts accessing systems that contain PHI.
2. MFA must be required for administrative accounts and remote access to critical company systems.
3. Employees must use company-approved authentication methods.
4. Phishing-resistant authentication methods, such as FIDO2 security keys or supported passkeys, should be used for administrative and high-risk accounts.

5. Employees must not share MFA codes, approve unexpected authentication requests, or register another person's authentication device.
6. Lost or compromised MFA devices must be reported to the IT Manager immediately.
7. The IT Manager must remove lost or unauthorized authentication methods from affected accounts.

4.4 Password Storage and Protection

1. Employees must use a company-approved password manager to store work-related passwords.
2. Passwords must not be stored in plain-text documents, spreadsheets, email messages, or unapproved applications.
3. Employees must not share passwords through Slack, personal email, or other unauthorized communication platforms.
4. Systems managed by MedBridge Health must store passwords using approved salted password-hashing methods.
5. Passwords must be transmitted only through encrypted, approved connections.
6. Employees must not save company passwords in unapproved browser profiles or personal password managers.

4.5 Administrative and Privileged Accounts

1. Administrative access must be assigned to individual accounts whenever the system supports it.
2. Shared administrator accounts must be removed or replaced with individually assigned accounts.
3. Administrative accounts must use MFA and follow the company's password requirements.
4. Employees must only receive administrative privileges when required for their job responsibilities.
5. Administrative access must be approved by the appropriate system owner.
6. Privileged accounts must be reviewed at least every six months.
7. Emergency or break-glass accounts must be documented, securely protected, monitored, and limited to authorized emergency use.

4.6 Account Management and Access Reviews

1. New employee accounts must be approved by the appropriate department manager before access is granted.
2. Employees must use their own assigned accounts and must not share them with other users.
3. The IT Manager must disable or remove employee access within 24 hours of a confirmed termination and immediately for high-risk departures.
4. User access permissions must be reviewed at least every six months.

5. Accounts that are no longer needed must be disabled or removed after confirmation from the responsible system owner.
6. Authentication systems must record relevant security events, including failed login attempts, account lockouts, and changes to authentication settings.
7. Repeated failed authentication attempts must be limited through approved rate-limiting or account-protection controls.

4.7 Authentication Security Monitoring

1. The IT Manager or designated technical staff must review high-priority authentication alerts at least once every business day.
2. Suspicious login attempts, unexpected MFA requests, and unauthorized account changes must be investigated.
3. Employees must report unexpected account activity immediately after discovering it.
4. Authentication logs must be retained according to MedBridge Health's approved logging and retention requirements.
5. Authorized security personnel may perform approved password-security assessments to identify weak or compromised credentials.
6. Any credentials found to be compromised during an authorized assessment must be reset or otherwise secured.

---

5. Exceptions

MedBridge Health understands that some applications or systems may not support every password or authentication requirement because of technical limitations.

When this happens, an exception must be requested and approved before the system is allowed to operate outside the policy.

Exceptions cannot override applicable legal or regulatory requirements.

5.1 Exception Request Process

1. Employees or department managers must submit a request explaining which authentication requirement cannot be met and why an exception is needed.
2. The request must identify the affected accounts, systems, or information and describe the potential security risks.
3. The vCISO must review the request and recommend additional security measures when necessary.
4. The appropriate system owner must review the business need for the exception.
5. The CEO must approve exceptions involving high or critical risks. Lower-risk exceptions may be approved by the vCISO.

6. All approved exceptions must be recorded in the company's exception register and include an expiration date.

5.2 Exception Monitoring and Review

The vCISO must review approved exceptions at least every 90 days to make sure the risks are still understood and any required security measures remain in place.

Exceptions must be reviewed again before they expire. If an exception is no longer needed, the affected account or system must return to following the original policy requirement.

Exceptions involving systems that contain PHI must also be reviewed by the Privacy Officer.

6. Enforcement

All MedBridge Health employees, contractors, and authorized third-party personnel are expected to follow the password and authentication requirements outlined in this policy.

Failing to follow these requirements could lead to compromised accounts, unauthorized access, and exposure of sensitive patient or company information.

If someone violates this policy, MedBridge Health will review the situation and determine the appropriate action based on the seriousness of the violation.

Depending on the situation, corrective actions may include:

- **Additional Security Training:** Employees may be required to complete additional training on password security and account protection.
- **Written Warning:** Employees may receive a formal warning for failing to follow authentication requirements.
- **Access Restrictions:** Access to certain accounts, systems, or applications may be temporarily restricted or removed.
- **Disciplinary Action:** Serious or repeated violations may lead to further disciplinary action, including termination of employment.
- **Contractual Action:** Contractors or third-party vendors who violate the policy may face consequences under their agreements with MedBridge Health.

The HR Manager will work with department leaders when employee disciplinary action is required.

The IT Manager and vCISO will review authentication-related violations and recommend actions to address any security risks identified.

If a violation involves unauthorized access to patient information, the Privacy Officer must also be notified to determine whether further investigation or reporting is required.

MedBridge Health will handle policy violations consistently and consider the severity of the incident, its impact, and whether the violation was intentional or accidental.

7. Related Policies and References

MedBridge Health's Password and Authentication Policy is based on cybersecurity standards, healthcare regulations, and security guidance related to password protection, identity management, and access control.

These references help the company establish authentication requirements and keep this policy consistent with its overall cybersecurity program.

7.1 Related Security Policies

The following policies support MedBridge Health's Password and Authentication Policy:

- **Information Security Policy:** Establishes the company's overall requirements for protecting sensitive information, managing cybersecurity risks, and controlling access to company systems.
- **Acceptable Use Policy:** Explains how employees and contractors must use company devices, accounts, and other technology resources.
- **Incident Response Policy:** Defines how suspected account compromises and other cybersecurity incidents must be reported, investigated, and addressed.

7.2 Regulations, Frameworks, and Standards

Reference	Purpose
HIPAA Security Rule (45 CFR Part 164, Subpart C)	Establishes security requirements for protecting electronic Protected Health Information (ePHI), including access controls and authentication safeguards.
NIST SP 800-63B-4 (2025)	Provides guidance on password requirements, authentication methods, compromised passwords, and account security.
NIST Cybersecurity Framework (CSF) 2.0	Provides guidance for managing cybersecurity risks, including identity management and access control.
ISO/IEC 27001:2022	Provides requirements for establishing and maintaining an information security management system.

SANS Password Construction Standard (April 2025)	Provides guidance on creating long passwords, using passphrases, and conducting authorized password-security testing.

7.3 Policy Review and Updates

The vCISO is responsible for reviewing this policy at least once every 12 months to make sure it remains relevant to MedBridge Health's authentication and security needs.

The policy must also be reviewed when major changes occur, such as new authentication technologies, updated security standards, or identified account security risks.

Any major changes must be approved by the CEO before the revised policy takes effect.

Employees and contractors must be informed of updates that affect how they access company systems.

8. Definitions

This section explains some of the cybersecurity and authentication terms used throughout MedBridge Health's Password and Authentication Policy.

Term	Definition
Password	A secret combination of characters used to verify a user's identity when accessing an account or system.
Passphrase	A password made up of multiple words or a longer sequence of characters.
Multi-Factor Authentication (MFA)	An authentication method that requires two or more different authentication factors to verify a user's identity.
Phishing-Resistant MFA	An authentication method designed to prevent users from accidentally providing reusable authentication credentials to fraudulent websites.
FIDO2	An authentication standard that supports phishing-resistant authentication through compatible security keys and passkeys.

Password Manager	An application used to securely store, organize, and manage passwords.
Compromised Password	A password that has been exposed, stolen, or otherwise obtained by an unauthorized individual.
Privileged Account	An account with elevated permissions used to manage systems, applications, or security settings.
Shared Account	An account used by more than one person, making individual actions harder to track.
Account Recovery	The process of restoring access to an account after a user loses or cannot use their authentication method.
Access Control	Security measures used to manage who can access systems, applications, and information.
Virtual Chief Information Security Officer (vCISO)	An external security professional who helps manage an organization's cybersecurity program and security strategy.
Protected Health Information (PHI)	Patient health information that can identify an individual and is protected under HIPAA.
Policy Exception	A formally approved, temporary allowance to operate outside a specific security policy requirement.

---

9. Document Control

This section documents the ownership, approval, and review requirements for MedBridge Health's Password and Authentication Policy.

The vCISO is responsible for maintaining the policy and making sure it is reviewed regularly. The CEO is responsible for approving the policy before it officially takes effect.

9.1 Policy Information

Field	Details

Policy Title	Password and Authentication Policy
Organization	MedBridge Health, Inc.
Policy ID	MBH-PAP-003
Version	1.0
Policy Owner	Virtual Chief Information Security Officer (vCISO)
Policy Approver	Chief Executive Officer (CEO)
Effective Date	Pending Approval
Last Review Date	Not Yet Reviewed
Next Review Date	12 months after approval
Review Frequency	Annually
Policy Status	Draft — Pending Approval

9.2 Policy Review and Approval

The vCISO must review this policy at least once every 12 months or whenever significant changes occur that could affect MedBridge Health's authentication requirements.

Any updates must be documented and submitted to the CEO for approval before the revised policy takes effect.

Employees and contractors must be informed of changes that affect how they manage passwords, use MFA, or access company systems.

9.3 Version History

Version	Date	Description	Updated By
1.0	November 2, 2026	Initial draft of the Password and Authentication Policy	vCISO (Simulated)

9.4 Document Disclaimer

This Password and Authentication Policy was created for MedBridge Health, Inc., a fictional healthcare organization, as part of a hands-on GRC lab by Andree Salvo. All policy requirements, responsibilities, and approval processes are simulated and they do not represent any officially implemented security programs.